

PERSONAL DATA BREACH NOTIFICATION AND PRIVACY INCIDENT RESPONSE PROCEDURE

No. BAL/MIS/24-25/080; Date. 31-Jan-2025

This document governs
privacy breach
notification and
incident response
procedure at BAL

Bajaj Auto Limited, hereinafter referred to as “We” or “Us” or “Organization” or “BAL”, has created this procedure document to demonstrate its commitment to maintain privacy of its customers /data subjects by safeguarding their personal data.

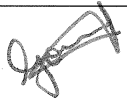
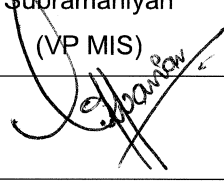
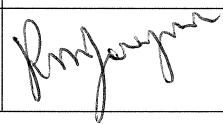
Reference			
Version		Status	
1.0		Released	
Author		Audience	
Govind Gopakumar		C2 - Bajaj Auto Restricted	
Version Updates			
Created/Modified By		Date	Version Modified
Name	Designation		
A V Jefferson	Asst. Mgr	31-01-2025	Original
Version History		Summary of Modification	
1.0			
Policy No.			
BAL/MIS/24-25/080			
Department		Date (Latest Update)	
MIS		31-01-2025	
Coverage			
Initiated By	Reviewed By		Approved By
Govind Gopakumar (Asst Mgr MIS)	Sanjay R. Ambadkar (DM MIS)	Badri Narayana Subramaniyan (VP MIS)	Rajeev Jorapur (Head MIS)
			

Table of Contents

1. Objective	3
2. Overview	3
3. Scope	3
4. Procedure	3
5. Privacy Breach Notification and Incident Response Workflow	7
6. Identify	8
7. Assess	8
8. Respond	9
9. Resolve	9
10. Personal data breach notification	11
11. Notification of a personal data breach to the relevant authority	11
12. Communication of a personal data breach to the Data Subject	12
13. Review frequency	12
14. Appendix	12

1. Objective

The objective of this procedure document is to ensure timely detection, reporting, and response to personal data breaches, while ensuring compliance with applicable data privacy/protection regulation. It aims to minimize the impact of breaches and promote continuous improvement in data protection practices.

2. Overview

This procedure document outlines the steps and protocols to be followed during a personal data breach or privacy incident involving personal data. It provides a structured approach for identifying, reporting, assessing, and responding to such incidents that compromise the confidentiality, integrity, or availability of personal data. The document defines roles and responsibilities for the privacy incident response team, including immediate actions to mitigate damage, notify affected data subjects, and report to regulatory authorities within required timelines.

Additionally, it outlines procedures for investigating the cause of the breach, containing the privacy incident, and implementing corrective actions to prevent future occurrences.

Please note that for the purpose of this document, the use of “data” and “information” shall be considered synonymous and has been used interchangeably. For the purpose of this document, the term personal data refers to customer personal data.

3. Scope

This procedure applies to all activities, processes, systems, and personnel involved in the processing of customer personal data related to connected electric vehicles to ensure compliance with applicable data privacy/protection regulation in all personal data processing activities across Bangladesh, Brazil, Colombia, Greece, Indonesia, Kenya, Mexico, Nepal, Philippines, Portugal, Saudi Arabia, Spain, Sri Lanka, Thailand, Turkey, UAE.

Please refer Appendix e for country specific regulation. The appendix covers the Data Privacy Breach requirement for the countries listed above.

This appendix needs to be monitored every six months and any changes to the respective country specific privacy related regulation should be incorporated.

4. Procedure

a. Privacy Incident Response tenets

- **Detection and Reporting:** Identify the privacy incidents through monitoring tools deployed, system alerts, a direct phone call by the business user. The on-ground support team must visit the affected area immediately (where applicable) and inform the status to the Privacy Champion. The Privacy Champion must log the privacy incident in the ITSM tool capturing all the relevant details and notify the Investigator immediately.

- Initial Assessment: The investigator assesses the privacy incident to confirm its status and identifies the affected systems (people, process, technology, or data) and services.
- Categorization: Based on the nature of the incident, a categorization must be done –
 - Personal data Breach - Includes data such as names, addresses, phone numbers, email addresses, and other personal identifiers.
 - Sensitive personal data Breach- Includes information that is more sensitive and may cause significant harm to data subjects if exposed, such as racial or ethnic origin, religious beliefs, location data and biometric data.
- Incident Assignment: Assign the privacy incident to the appropriate technical team based on the categorization. Include technical team of third party, if required to resolve the incident.
- Common Bridge Initiation: Initiate a common bridge with all relevant team members to discuss the initial findings, come up with a resolution plan, and identify the root cause discuss. Ensure high leadership (L2 and L1 leaders in BAL) within the Privacy domain is briefed on the privacy incident during the bridge.
- Involve the L2/L3/L4 Technical teams based on the levels of support required to troubleshoot the privacy incident. A defined timeline should be planned in engaging the next level teams/skills required to troubleshoot the privacy incident based on the urgency arising and the expertise demanded in the bridge.
- Functional and Hierarchical Escalation: The DPO along with the help of L3 Manager from BAL (if needed) performs Functional / Hierarchical Escalation activity until closure of S1 Incident. Functional (Technical) escalation is defined as involving personnel with specialized skills, time, and/or access privileges to assist in resolving the Privacy incident. Hierarchical escalation is defined as involving personnel higher in the organization to expand the scope of control and management responsibility.
- Root Cause Analysis: Conduct a thorough investigation to identify the root cause of the privacy incident and document the findings and steps taken during the investigation. Share the SOP with the BAL Data Privacy team post the privacy incident is resolved.
- Resolution and Recovery: Implement the necessary changes/fixes to resolve the privacy incident. Verify that the incident has been fully resolved and all systems are functioning correctly.
- Communication: Provide regular updates based on the criticality of the privacy incident to all the stakeholders throughout the incident resolution process. Notify stakeholders once the incident is resolved and services are restored.
- Post Incident review: After the privacy incident has been resolved, a postmortem review will be conducted directly following the troubleshooting bridge (if time

permits) or scheduled the following business day with the people involved in the resolution and other key members.

b. Privacy Incident Response Procedure

In case of a privacy event, the following table outlines the roles and responsibilities necessary for a proficient response, investigation, and prevention of potential privacy incidents, to avert their escalation into personal data breaches.

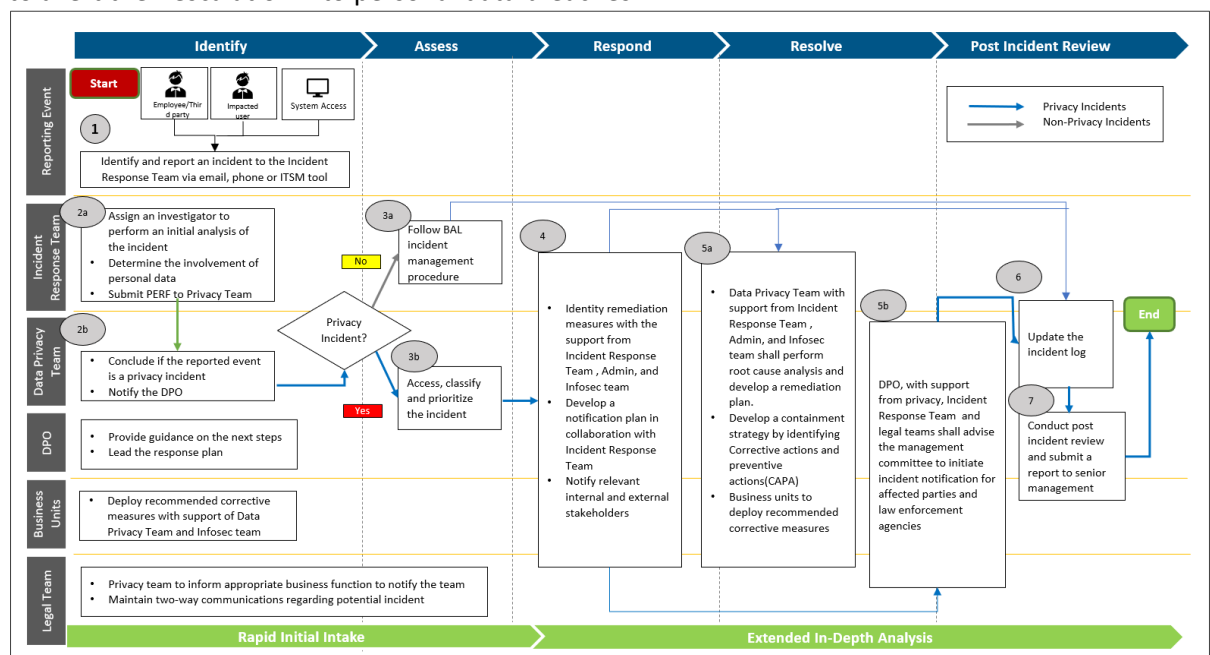
S.no.	Role/Team	Responsibilities
1.	Affected person	To immediately notify the Incident Response Team regarding suspected privacy incident that may lead to a personal data breach by raising an ITSM ticket. <i>(In line with the Information security incident process)</i>
2.	Privacy Incident Response Team	- Designate an investigator to determine if the reported event contains/affects personal data and if the privacy event is an actual privacy incident. - Notify the Data Privacy Team regarding the involvement of personal data in a reported privacy incident. - Perform Root Cause Analysis with the Data Privacy Team. Leverage support from appropriate departments of the BAL to prevent the recurrence of the privacy incidents.
3.	Investigator	- Assess the event and identify whether personal data is involved in the reported event. - Classify the event as a Privacy Event and report to the Incident Response Team to invoke the Data Privacy Team. - Receive and review the PERF(Privacy Event Reporting Form) that is being submitted and initiate the incident response accordingly. - Investigate and conclude if the reported event is classified as a privacy incident. - Ensure that adequate evidence of the privacy incident is maintained, and the measures implemented to counteract the consequences of such an incident are documented and preserved.
4.	Data Privacy Team	Address the suspected privacy incident reported by the Incident response team.

		• Notify PERF (Privacy Event Reporting Form) to the DPO. • Maintain the overall status of the privacy events and incidents. • Designate privacy champions to coordinate with the Data Privacy Team in case of any breach or for implementation of the Corrective Action and Preventive Action (CAPA) plan into the business unit(s) processes as per the privacy requirements. • Assess the nature and scope of the privacy incident to determine and assign risk levels. • Initiate the development of the privacy incident response plan and internal communications to notify appropriate stakeholders. • Plan for remedial actions that also include notifications to external parties (e.g., law enforcement agencies, customers, third parties, and relevant regulatory authorities) regarding the privacy incident within the designated timeframe. • Convene additional functional groups as required, based on the nature of the privacy incident, to execute the privacy incident response plan. • Contain and control the privacy incident with support from Incident Response team, Physical security, and IT Teams. • Coordinate with the appropriate operational functions to issue notifications to the target recipients.
5.	Data protection officer (DPO)	• Provide guidance and authorization on the privacy incident response process and coordinate with the relevant stakeholders from the business units for the privacy incident response activities. • Verify and ensure all evidence maintained as part of the personal data breach is shared with the relevant authorities or any other government agencies as applicable in the respective country regulation.
6.	Business Units	• Heads of business units must ensure liaison with privacy champion from Data Privacy Team for conducting the analysis and preparing to deploy the recommended corrective measures. • Prepare to deploy the recommended corrective measures as soon as possible.

7.	MIS Infra & Infosec Team	- Examines system logs of critical systems for unusual activity and ensures that backups are in place for all the critical systems processing personal data, sensitive personal data, or special categories of personal data and critical personal data. - Responsible for contacting external Internet Service Providers (ISPs) for assistance in dealing with the privacy incident, wherever necessary. In case of any unusual activity, the team shall take all necessary action to block traffic from the suspected intruder.
8.	Legal Team	Support in complying with applicable data privacy/protection regulation and contractual obligations.
9.	Third Parties	- As included within the language of the agreement with BAL, the third parties are contractually obligated to notify their Single Point of Contact (SPOC) in case of a privacy incident involving the personal data of BAL. - The SPOC shall raise a PERF after obtaining the information from the third party. As such the PERF and related documents shall be made available to the third parties.

5. Privacy Breach Notification and Incident Response Workflow

In case of a suspected privacy event, the following table outlines the roles and responsibilities necessary for a proficient response, investigation, and prevention of potential privacy incidents, to avert their escalation into personal data breaches.



6. Identify

- All individuals affiliated with BAL, including employees, contractors, vendors, suppliers, and others, shall promptly communicate any suspected privacy events to the designated Incident response team and record the event through ITSM tool.
- In cases where it is confirmed that personal data is impacted, the investigator shall notify the Incident Response Team to involve the Data Privacy Team.
- The Data Privacy Team shall be entrusted with the task of completing the **Privacy Event Reporting Form (PERF)** and categorizing the reported event accordingly. Simultaneously, they shall create a potential incident record to facilitate tracking and management.
- The finalized PERF form shall be submitted to the Data Protection Officer (DPO) through appropriate channel. This meticulous reporting process ensures that any suspected privacy incident is reported promptly and adheres to a structured workflow that enables swift assessment and appropriate action.

7. Assess

- Upon receipt of the PERF (Privacy Event Reporting Form) from the investigator, the Data Privacy Team shall determine whether the reported privacy event is a privacy incident and duly notify the DPO to seek guidance on the investigation, evidence collection, remediation measures, and communications.
- If the reported event does not involve personal data, then the BAL's Information Security Incident Response Process shall be followed.
- If the reported event is classified as a privacy incident, then the privacy incident response process shall be initiated by the Data Privacy Team.
- The Data Privacy Team shall promptly acknowledge receipt of the privacy incident and then perform a thorough evaluation. During this process, the team will assess the nature, scope, and severity of the incident, and classify it accordingly. Afterward, all relevant details about the privacy incident will be recorded and updated in the Privacy Incident Tracker.
- The privacy incidents shall be subjectively classified based on the severity as S1, S2, S3 or S4 based on an evaluation of the following parameters:

Severity description matrix

- **S1 Incident** – A large-scale data breach or leak involving a significant number of data subjects and sensitive personal data. This may cause severe harm with high probability of identity theft, financial loss, or legal consequences. Immediate action and breach notification are required. An example of this type of incident is "Large-Scale Data Breach Involving customer personal data".
- **S2 Incident** - High-impact incidents affecting business operations or data confidentiality, requiring prompt resolution. May require breach notification in some cases. An example- Unauthorized access to data, malware/phishing attacks, data leakage, service disruptions
- **S3 Incident:** Moderate impact on operations or data, with no immediate risk to reputation or compliance. Requires investigation and remedial action. Examples include the exposure of contact information or incorrect sharing of data.
- **S4 Incident** – Minimal impact on business operations or data.

	S4	S3	S2	S1
Response	24 business hrs.	24 business hrs.	24 business hrs.	3-4 business hours.
Closure	5 business days	4 business days	3 business days	2 business days

8. Respond

- The Privacy Champion from Data Privacy Team shall notify the DPO regarding the privacy incident.
- Based on the severity of the privacy incident, the Data Privacy Team shall with the help of DPO initiate the development of the privacy incident response plan and internal communications to notify appropriate stakeholders.
- The Data Privacy Team with guidance from the DPO, shall devise a plan for remedial actions that also includes notifications to external parties (e.g., law enforcement agencies, customers, third parties, and relevant data protection authorities) regarding the privacy incident within the designated timeframe.
- Based on the type of privacy incident, notification shall be shared either simultaneously or after the containment of the privacy incident.
- The Data Privacy Team shall coordinate with the Incident Response Team or other appropriate operational functions to issue notifications to the target recipients.

The Data Privacy Team along with the Incident Response Team, legal team and MIS Infra and Infosec Team shall identify a containment strategy based on the following key activities:

- Identify potentially affected computer systems and network equipment.
- Identify locations where additional relevant data may reside.
- Identify potential vulnerabilities suspected to have been exploited during the privacy incident.
- If the privacy incident is not yet contained, the compromised system(s) may need to be disconnected from the BAL network.
- Communicate with affected individuals about the privacy incident and its impact.
- Assist affected individuals with questions or concerns related to the privacy incident.
- Legal team to assess potential legal liabilities and risks,
- Determine if regulatory authorities need to be notified,
- Review agreements with third parties for legal implications, and
- Provide legal analysis and support for decision-making.

9. Resolve

- **Document Privacy incident Response Actions**

The Data Privacy Team shall document all the activities associated with the privacy incident, including the actions taken, decisions made, and the final remediation activities.

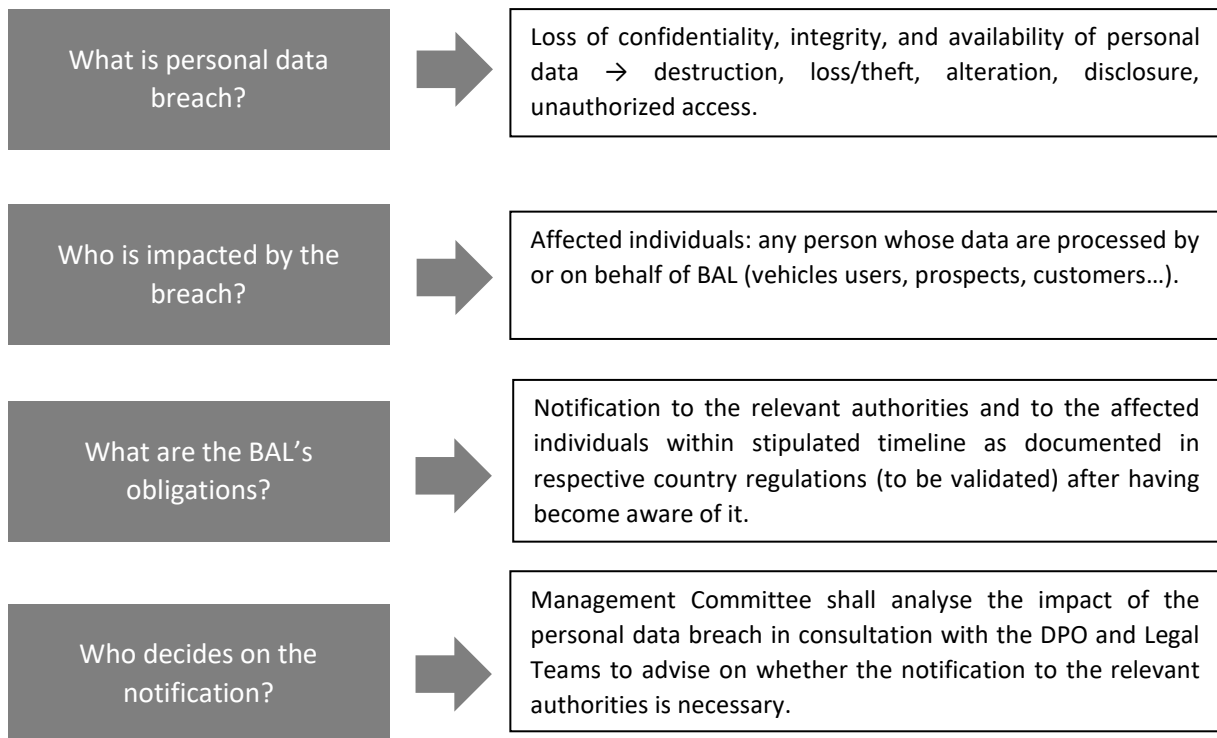
- **Perform Root Cause Analysis (RCA):**
 - Root Cause Analysis shall be performed with the involvement of relevant business units/departments of the BAL to prevent the recurrence of the privacy incidents.

- The Data Privacy Team shall document the privacy incident log accordingly regarding the reported privacy incident.
- If required initiate notification for the affected parties which also includes law enforcement agencies, customers, third parties, and relevant regulatory authorities.
- **Identifying Corrective Actions and Preventive Actions (CAPA):**
 - The Data Privacy Team shall liaison with the business units to identify appropriate measures to prevent the occurrence of similar privacy incidents in the future.
 - The Data Privacy Team shall review the privacy incident and present a report on it to the senior management.
- **Privacy incident tracking**

The Data Privacy Team shall record the details, as provided in the PERF, in the privacy incident tracker. The tracker shall implement access controls so that only the Incident Response Team and Data Privacy Team can view a list of privacy incidents along with incident details, which may or may not be classified as an incident. (Refer to appendix for a sample template for the Privacy Incident Tracker).

10. Personal data breach notification

Based on the assessment of the privacy incident and classification as a personal data breach by the Data Privacy Team in consultation with the DPO, a notification of the personal data breach shall be provided to the relevant authorities and other relevant external stakeholders/government agencies, within the period specified by the applicable data privacy/protection regulation.



11. Notification of a personal data breach to the relevant authority

Where BAL is a Data Controller: In the event of a personal data breach, the data controller must notify the data protection authority without undue delay, where applicable as per the country data privacy/protection regulation, within 72 hours of becoming aware of the breach. This is unless the breach is unlikely to result in a risk to the rights of data subjects. If the notification is not made within 72 hours or stipulated time (whichever applicable), the data controller must provide an explanation for the delay.

Where BAL is a Data Processor: If the said personal data breach involves the personal data and such a breach may lead to potential harm to the Data Subject, BAL shall notify the Data Controller without undue delay after becoming aware of the privacy incident.

The notification provided to the data protection authority shall contain the below-listed details regarding the personal data breach:

- Describe the nature of the personal data breach including where possible, the categories and approximate number of Data Subjects concerned, and the categories and approximate number of personal data records concerned.
- Communicate the name and contact details of the DPO or relevant authority to obtain more information regarding the personal data breach.
- Describe the likely consequences of the personal data breach.
- Describe the measures taken or proposed to be taken by BAL to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

Where it is not possible to provide the information at the same time, the information may be provided in phases without undue delay. BAL shall document any personal data breaches, comprising the facts relating to the personal data breach, its effects, and the remedial action taken. That documentation shall enable the relevant authorities to verify compliance as and when required.

12. Communication of a personal data breach to the Data Subject

When the personal data breach may lead to potential harm to the Data Subject's rights, BAL shall communicate the same to the Data Subject without undue delay. The communication to the Data Subject shall describe in clear and plain language the nature of the personal data breach and contain at least the information and measures taken to address the personal data breach. However, communication to the Data Subject shall not be required if any of the following conditions are met:

- BAL has implemented appropriate technical and organizational protection measures, and those measures were applied to the personal data affected by the personal data breach those that render the personal data unintelligible to any person who is not authorized to access it, such as encryption.
- BAL has taken subsequent measures, which ensure that the high risk to the rights and freedoms of Data Subjects is no longer likely to materialize.
- It would involve a disproportionate effort. In such a case, there shall instead be a public communication or similar measure whereby the Data Subjects are informed equally and effectively.

13. Review frequency

This document is subject to annual review or earlier if there are changes in the business environment or applicable data privacy/protection regulations. Any updates to this document will be recorded at the beginning of the document.

14. Appendix

a. Sample Privacy Event Reporting Form (PERF) to data subject - Indicative

From: Bajaj Auto Limited

To: [Affected Data Subject's Name and Address]

1. Dear customer/ user, we regret to inform you that on [date] we have discovered that, we have been the subject of a personal data breach.
2. As a result of the above-mentioned personal data breach, the personal data concerning you might have been:

- ☐ Disclosed
- ☐ Destroyed
- ☐ Lost
- ☐ Modified
- ☐ Accessed
- ☐ Other [please specify other possible results]

Type/Write here

3. Please be aware that the personal data breach might have the following consequences:

- ☐ Data subjects may be subject to unsolicited emails.
- ☐ Data subjects may be subject to phishing attempts.
- ☐ Data subjects may be subject to fraud attempts.
- ☐ Legal consequences for BAL
- ☐ Service downtime
- ☐ Any other (Please list) _____

4. The following measures have been taken/will be taken to address the data breach:

- ☐ Took affected devices offline.
- ☐ Communicated details of the breach to appropriate internal personnel & external regulators
- ☐ Made public announcements, where required.
- ☐ Moved the database to a secure location/ server.
- ☐ Reviewed the existing security measures and are in process of strengthening them.
- ☐ Changes critical passwords and other locking credentials.
- ☐ In process of deploying encryption mechanisms
- ☐ Determined the overall impact.
- ☐ In process of investigating the root cause
- ☐ Determined steps/ actions that can avoid such breaches in future.

☐ Any other (Please list)

Type/Write here _____

If you have any questions or concerns regarding the data breach, we encourage you to contact our Data Protection Officer, by email at [privacy@bajajauto.co.in], or by post at [Data Protection Office, Bajaj Auto Limited, Mumbai – Pune Road, Akurdi, Pune – 411 035 India].

b. Sample Privacy Incident Reporting Form (PERF)- Supervisory Authority - Indicative

Dear _____,

This is to inform you that the following Data Security Breach has been identified by BAL:

Type of Data Security Breach:	
Date of Occurrence of Data Security Breach:	
Date of Identification of Data Security Breach:	

Client (Full Name (If applicable):	
Description of Data Security Breach: (Summary & Circumstances)	
Type and Amount of personal data:	
Impact of Data Security Breach:	

Action Plan :

S No.	Type of Action*	Action Details	Target Completion Date(s)*	Actual Completion Date(s)*
1	Correction(Immediate action)			
2	Recovery measures			

*Rows can be added in case of multiple actions.

For BAL use only**:	
Date of Notification(DD/MM/YYYY):	

Action Plan Course Date(DD/MM/YYYY):			
Closure By:			
_____	_____	__/__/____	
Name	Signature	(DD/MM/YYYY)	

**To be completed by DPO

c. Sample Privacy Incident Tracker Template - Indicative

The sample template for building the Privacy Incident Tracker is available.

d. Definitions

- **Data Subjects:** A data subject is a living person whose personal data is collected, stored, or processed.
- **Personal data:** Any information relating to an identified or identifiable natural person. An identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors.
- **Sensitive Personal Data (SPD):** Personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a person, health data, data concerning a person's sex life or sexual orientation.
- **Controller:** A "Data Controller" means a natural or legal person, public authority, agency, or other body that determines the purposes and means of the processing of personal data. In simpler terms, the "Data Controller" is the entity that decides why and how personal data is collected, processed, stored, shared, etc., for non-personal use.
- **Processor:** "Data Processor" means any person, including the State, a company, any juristic entity, or any individual, who processes personal data on behalf of the Data Controller.
- **Processing:** An operation or set of operations performed on personal data, and may include operations such as collection, recording, organization, structuring, storage, adaptation, alteration, retrieval, use, alignment, or combination, indexing, disclosure by transmission, dissemination or otherwise making available, restriction, erasure, or destruction.
- **Customer:** A customer is a person who buys goods or services from another business
- **Privacy Event:** A Privacy Event is any event that points to the possibility of a Privacy Incident. A Privacy Event could be an employee, contractor, or another external party complaint, a management alert, or an automated information security alert that suggests that a privacy incident may have occurred. All privacy events require further investigation to conclude whether a privacy incident has occurred.

- **Privacy Incident:** A Privacy Incident consists of an unauthorized or inappropriate collection, use, access, disclosure, or modification of personal data.
- **Personal data Breach:** Any unauthorized or accidental disclosure, acquisition, sharing, use, alteration, destruction, or loss of access to the personal data that may compromise confidentiality, integrity, availability and linkability, traceability, or identifiability of personal data to a Data Subject.
- **Privacy champions:** BAL personnel who have been chosen by the respective business unit heads. By incorporating privacy standards into their department's daily operations, the privacy champion makes sure that the rules and practices relating to privacy are understood by the organization.
- **Third-Party:** A natural or legal person, public authority, agency, or body other than the data subject, controller, processor, and persons who, under the direct authority of the controller or processor, are authorized to process personal data.

****NOTE:** The definitions listed above may vary as per the scope of the document. Please refer the Country specific requirement sheet: Definitions for specific country

e. Applicable Regional Specific Laws

Below is a list of the countries within scope and their corresponding data protection regulations. Please refer the detailed requirements of each country in the excel sheet.

S. No.	Country	Regulation
1	Thailand	Personal Data Protection Act 2019 ('PDPA')
2	Sri Lanka	Personal Data Protection Act
3	Nepal	Privacy Act 2075 (2018);
4	Bangladesh	The Data Protection Bill, 2023 (Draft)
5	Indonesia	The Personal Data Protection Law, 2022 (PDPL)
6	Saudi Arabia	1. Personal Data Protection Law (PDPL) 2021 2. Personal Data Protection Interim Regulations (PDPIR)
7	UAE	UAE Federal Decree-Law No. 45 of 2021 on the Protection of Personal Data
8	Mexico	The Federal Law on the Protection of Personal Data held by Private Parties - 2010
9	Turkey	Law on the Protection of Personal Data No. 6698 dated April 7, 2016 (LPPD).
10	Kenya	Data Protection Act (DPA), 2019
11	Colombia	Law 1581 of 2012 (General Personal Data Protection Law)
12	Philippines	The Data Privacy Act of 2012(DPA)
13	Brazil	Law No. 13.709 of 14 August 2018, General Personal Data Protection Law ('LGPD')
14	Greece	The General Data Protection Regulation (GDPR) 2018
15	Portugal	
16	Spain	